Corso di Cybersecurity – Epicode

Report dell'Esercitazione

Scansione di rete con Nmap su Metasploitable2

Individuazione dell'host, delle porte aperte e dei servizi in esecuzione

A cura di:

Nicola Madonna

Epicode

17 ottobre 2026

Indice

1 Riassunto 2
2 Obiettivi 2
3 Configurazione del Laboratorio 3
3.1 Ambiente 3
3.2 Verifica della raggiungibilità 4
4 Analisi dei Dati Raccolti 5
4.1 Ricerca degli host 5
4.2 Scansione di tutte le porte TCP 6
4.3 Servizi, versioni e sistema operativo 7
4.4 Servizi più a rischio 10
4.5 Contromisure 11
5 Conclusioni 12

1 Riassunto

In questo laboratorio è stata eseguita da una macchina Kali Linux una scansione con Nmap contro Metasploitable2, una macchina virtuale volutamente vulnerabile collegata alla stessa rete interna isolata. La ricerca degli host ha individuato il bersaglio all'indirizzo `192.168.200.102`. La scansione SYN su tutte le 65.535 porte TCP ha rilevato **30 porte aperte**, e la scansione di versione ha identificato i servizi in ascolto, quasi tutti con versioni vecchie di molti anni (ad esempio vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8 e Samba 3.0.20), e il sistema operativo (Linux 2.6.x). Tra le evidenze più gravi ci sono l'accesso FTP anonimo, il servizio Telnet in chiaro e una shell in ascolto sulla porta 1524, che Nmap descrive come *Metasploitable root shell*. Il risultato mostra quanto sia ampia la superficie di attacco di un sistema con molti servizi inutili esposti e non aggiornati.

2 Obiettivi

- Predisporre un piccolo laboratorio con una macchina di scansione e un bersaglio sulla stessa rete isolata.
- Individuare gli host raggiungibili e le porte TCP aperte del bersaglio.
- Riconoscere servizi, versioni e sistema operativo con la scansione di versione di Nmap.
- Valutare quali servizi espongono i rischi maggiori e come ridurli.

3 Configurazione del Laboratorio

3.1 Ambiente

Il laboratorio è composto da due macchine virtuali in VirtualBox collegate a una rete interna isolata, senza accesso a Internet né alla rete reale: le scansioni restano quindi confinate nel laboratorio. Kali Linux è la macchina da cui si scansiona, Metasploitable2 è il bersaglio (Tabella 1).

Tabella 1: Macchine del laboratorio.

Macchina	Ruolo	Indirizzo IP	Sistema operativo
Kali	scansione	192.168.200.100/24	Kali Linux
Metasploitable2	bersaglio	192.168.200.102/24	Linux (distribuzione Metasploitable2)

Gli indirizzi sono stati assegnati a mano nella rete `192.168.200.0/24`. Le Fig. 1 e Fig. 2 mostrano la configurazione dell'interfaccia `eth0` delle due macchine.



Figura 1: Configurazione di rete di Kali: interfaccia eth0 con indirizzo 192.168.200.100/24.

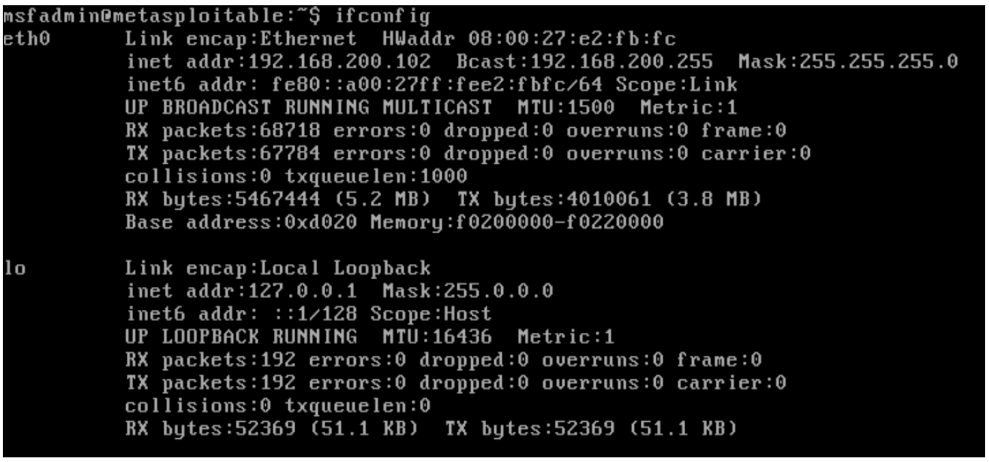


Figura 2: Configurazione di rete di Metasploitable2: interfaccia eth0 con indirizzo 192.168.200.102/24 e MAC 08:00:27:e2:fb:fc.

3.2 Verifica della raggiungibilità

Prima di scansionare è stata verificata la connettività con `ping` (Fig. 3): tutti e 3 i pacchetti hanno ricevuto risposta, con un tempo inferiore al millisecondo e un TTL di 64, valore tipico dei sistemi Linux.

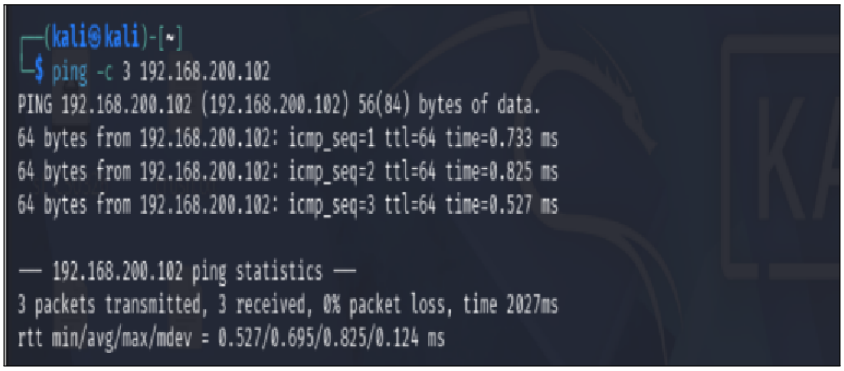


Figura 3: Ping da Kali a Metasploitable2: 3 pacchetti inviati, 3 ricevuti, TTL 64.

4 Analisi dei Dati Raccolti

4.1 Ricerca degli host

Per individuare gli host attivi nella rete è stata eseguita una scansione di sola scoperta, senza controllo delle porte:

```
sudo nmap -sn -T4 -n --open 192.168.200.0/24
```

L'opzione `-sn` limita Nmap alla ricerca degli host attivi, `-T4` rende la scansione più veloce e `-n` evita la risoluzione dei nomi DNS, che rallenta l'operazione. La scansione ha controllato i 256 indirizzi della rete in 8,01 secondi e ha trovato 3 host attivi (Fig. 4): `192.168.200.100`, cioè la Kali stessa, `192.168.200.102`, il bersaglio, e `192.168.200.101`, un'altra macchina del laboratorio non coinvolta in questa analisi. I MAC address dei due host remoti iniziano con `08:00:27`, il prefisso delle schede di rete virtuali di VirtualBox.



Figura 4: Ricerca degli host con nmap -sn: 3 host attivi su 256 indirizzi.

4.2 Scansione di tutte le porte TCP

Sul bersaglio è stata poi eseguita una scansione SYN su tutte le porte TCP:

```
sudo nmap -sS -p- -T4 -n 192.168.200.102
```

L'opzione `-sS` esegue una scansione SYN, detta anche *half-open*: Nmap invia un pacchetto SYN e, se riceve un SYN-ACK, la porta è aperta e la connessione viene interrotta con un RST prima di completare l'handshake; un RST come risposta indica invece una porta chiusa. L'opzione `-p-` estende il controllo a tutte le 65.535 porte, invece delle sole 1.000 più comuni usate di default.

La scansione è durata 10,06 secondi e ha trovato **30 porte aperte**; le altre 65.505 hanno risposto con un reset, cioè sono chiuse (Fig. 5). Molti servizi sono sulle porte note, ma altri si trovano su porte meno comuni, come la 3632, la 8787 o le porte alte da 37542 in su, che una scansione limitata alle porte predefinite non avrebbe mostrato.



Figura 5: Scansione SYN di tutte le porte: 30 porte aperte su 65.535.

4.3 Servizi, versioni e sistema operativo

Per identificare cosa è in ascolto sulle porte aperte è stata eseguita una scansione di versione, salvando il risultato su file:

```
sudo nmap -sV -sC -O -p- -T4 -n 192.168.200.102 -oN
    nmap_metasploitable_completo.txt
```

L'opzione `-sV` interroga le porte aperte per riconoscere servizio e versione, `-sC` esegue gli script predefiniti di Nmap (categoria *default*), che raccolgono informazioni aggiuntive, `-O` stima il sistema operativo e `-oN` salva l'output in un file di testo. La scansione è durata 164,35 secondi e il suo output è riportato nelle figure da Fig. 6 a Fig. 9.



Figura 6: Output di nmap -sV -sC -O (1 di 4): porte 21, 22, 23 e 25.

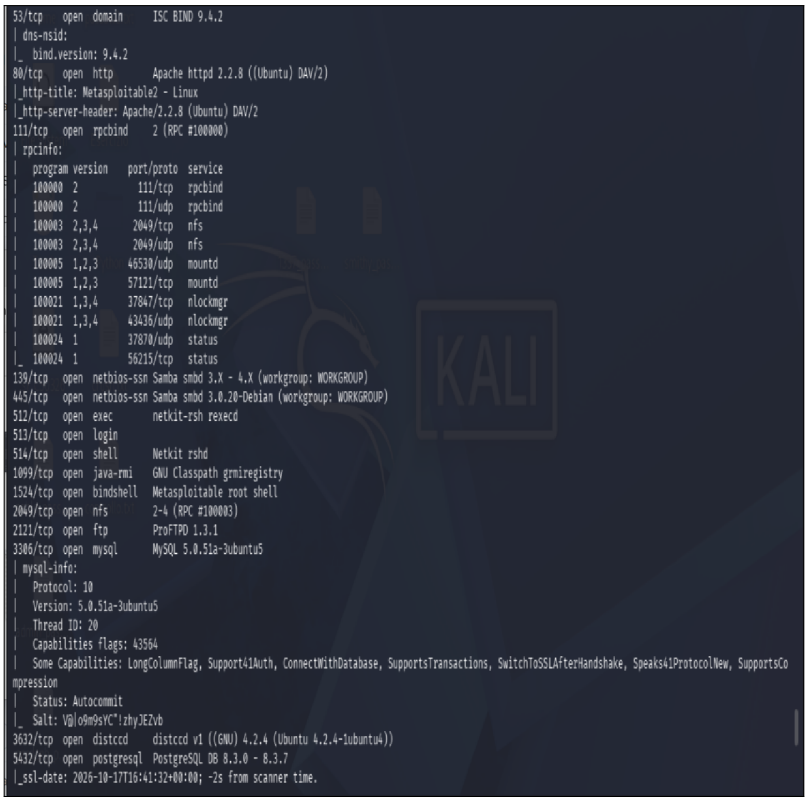


Figura 7: Output di nmap -sV -sC -O (2 di 4): dalla porta 53 alla porta 3632.



Figura 8: Output di nmap -sV -sC -O (3 di 4): dalla porta 5432 alla porta 57121, con la stima del sistema operativo.



Figura 9: Output di nmap -sV -sC -O (4 di 4): risultati degli script SMB e durata della scansione.

Nmap stima come sistema operativo un Linux con kernel 2.6.9–2.6.33 (`Running: Linux 2.6.X`), a un solo salto di rete. Gli script SMB riportano nome del computer `metasploitable`, dominio `localdomain` e Samba 3.0.20-Debian, in linea con il titolo della pagina web sulla porta 80, *Metasploitable2 - Linux*.

I risultati sono riassunti nella Tabella 2, in ordine di porta.

Tabella 2: Le 30 porte aperte, con servizio e versione rilevati da Nmap.

Porta	**Servizio**	**Versione rilevata**	**Note**
21/tcp	FTP	vsftpd 2.3.4	Accesso anonimo consentito
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	Protocollo 2.0
23/tcp	Telnet	Linux telnetd	Comunicazione in chiaro
25/tcp	SMTP	Postfix smtpd	SSLv2 supportato; certificato scaduto
53/tcp	DNS	ISC BIND 9.4.2	Versione visibile via bind.version
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2	Pagina: Metasploitable2 - Linux
111/tcp	rpcbind	2 (RPC #100000)	Elenca i servizi RPC
139/tcp	NetBIOS	Samba smbd 3.X - 4.X	Condivisione file
445/tcp	SMB	Samba smbd 3.0.20-Debian	Firma dei messaggi disabilitata
512/tcp	exec	netkit-rsh rexecd	Servizio r* in chiaro
513/tcp	login	versione non indicata	Servizio r* in chiaro
514/tcp	shell	Netkit rshd	Servizio r* in chiaro
1099/tcp	Java RMI	GNU Classpath grmiregistry	Registro RMI
1524/tcp	bindshell	Metasploitable root shell	Shell in ascolto
2049/tcp	NFS	2-4 (RPC #100003)	File system di rete
2121/tcp	FTP	ProFTPD 1.3.1	Secondo server FTP

Porta	Servizio	Versione rilevata	Note
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5	Database
3632/tcp	distccd	distccd v1 ((GNU) 4.2.4)	Compilazione distribuita
5432/tcp	PostgreSQL	PostgreSQL DB 8.3.0 - 8.3.7	Certificato scaduto
5900/tcp	VNC	VNC (protocollo 3.3)	Autenticazione VNC
6000/tcp	X11	versione non indicata	Accesso negato
6667/tcp	IRC	UnrealIRCd	Versione non indicata
6697/tcp	IRC	UnrealIRCd	Versione non indicata
8009/tcp	AJP13	Apache Jserv (protocollo 1.3)	Connettore AJP, di solito di Tomcat
8180/tcp	HTTP	Apache Tomcat/Coyote JSP engine 1.1	Tomcat 5.5
8787/tcp	DRb	Ruby DRb RMI (Ruby 1.8)	Oggetti Ruby remoti
37542/tcp	Java RMI	GNU Classpath grmiregistry	Secondo registro RMI
37847/tcp	nlockmgr	1-4 (RPC #100021)	Gestione dei blocchi NFS
56215/tcp	status	1 (RPC #100024)	Servizio di stato RPC
57121/tcp	mountd	1-3 (RPC #100005)	Montaggio delle condivisioni NFS

4.4 Servizi più a rischio

Le versioni rilevate risalgono in gran parte a molti anni fa: OpenSSH 4.7p1 e Apache 2.2.8 sono software del 2007 e 2008, Samba 3.0.20 è ancora più vecchio. La Tabella 3 raccoglie i servizi che destano maggiore preoccupazione. Le indicazioni si basano sulla versione e sul comportamento dichiarato dai servizi: Nmap non verifica se una vulnerabilità sia davvero sfruttabile, e per questo servono una scansione di vulnerabilità dedicata o una verifica manuale.

Tabella 3: Servizi più critici emersi dalla scansione.

Servizio (porta)	Evidenza in Nmap	Rischio
FTP anonimo (21)	Script `ftp-anon`: login anonimo consentito; vsftpd 2.3.4	Chiunque sia nella rete può accedere ai file esposti; la versione 2.3.4 è nota per una backdoor inserita nei sorgenti nel 2011 (CVE-2011-2523).
Telnet (23) e servizi r* (512-514)	Servizi attivi in chiaro	Credenziali e comandi viaggiano non cifrati; l'autenticazione dei servizi r* si basa su host considerati fidati.
Bindshell (1524)	Servizio identificato come *Metasploitable root shell*	Una shell di root in ascolto sulla rete, tipica di una backdoor: accesso diretto al sistema.
UnrealIRCd (6667, 6697)	Servizio IRC, versione non indicata	Su questa distribuzione è documentata una versione con backdoor (CVE-2010-2075), da verificare.

Servizio (porta)	Evidenza in Nmap	Rischio
Samba 3.0.20 (139, 445)	Samba smbd 3.0.20-Debian; firma dei messaggi disabilitata	Versione interessata da una vulnerabilità di esecuzione di comandi (CVE-2007-2447); senza firma SMB sono possibili attacchi man-in-the-middle.
distccd (3632)	distccd v1, GNU 4.2.4	Il servizio accetta lavori di compilazione da qualunque client e può permettere l'esecuzione di comandi (CVE-2004-2687).
Tomcat e AJP (8180, 8009)	Apache Tomcat 5.5; connettore Jserv	Versione molto datata e fuori supporto; interfaccia di gestione e connettore AJP vanno protetti.
Java RMI e DRb (1099, 37542, 8787)	grmiregistry; Ruby DRb RMI	Servizi di oggetti remoti senza restrizioni di accesso possono permettere l'esecuzione di codice.
NFS e RPC (111, 2049, 57121)	rpcbind, nfs e mountd raggiungibili	Esportazioni NFS non restrittive possono rendere leggibili o scrivibili i file del sistema.
SMTP (25)	SSLv2 con cifrari deboli; certificato scaduto (2010); VRFY attivo	Cifratura facilmente violabile e possibilità di enumerare gli utenti.
Database (3306, 5432) e VNC (5900)	MySQL 5.0.51a, PostgreSQL 8.3.x, VNC con password	Servizi raggiungibili dalla rete con versioni molto vecchie e credenziali potenzialmente deboli.
OpenSSH, BIND e Apache (22, 53, 80)	OpenSSH 4.7p1, BIND 9.4.2, Apache 2.2.8 con WebDAV	Software non più aggiornato, con molte vulnerabilità pubbliche note.

4.5 Contromisure

In un ambiente reale il sistema andrebbe messo in sicurezza così:

- **Ridurre la superficie di attacco:** disattivare i servizi non necessari (Telnet, rexec, rlogin, rsh, distccd, DRb, RMI) e chiudere con un firewall le porte che non servono.
- **Usare protocolli cifrati:** SSH al posto di Telnet e dei servizi r*, SFTP o FTPS al posto di FTP senza accesso anonimo, solo TLS aggiornato con certificati validi e firma dei messaggi SMB abilitata.
- **Aggiornare il software:** sostituire le versioni obsolete con versioni supportate e applicare le patch di sicurezza.
- **Limitare l'accesso:** consentire database, VNC e interfacce di gestione solo da indirizzi fidati o dall'interfaccia locale.
- **Trattare la bindshell come un incidente:** una shell di root in ascolto, come quella sulla porta 1524, indica una possibile compromissione e richiede di reinstallare il sistema.

5 Conclusioni

Con tre scansioni progressive di Nmap è stato possibile ricostruire il profilo del bersaglio: prima l'individuazione dell'host nella rete, poi le 30 porte TCP aperte e infine servizi, versioni e sistema operativo. Il quadro che ne risulta è quello di un sistema Linux con molti servizi inutili esposti, in gran parte obsoleti, alcuni dei quali in chiaro o con backdoor note.

Per un analista SOC la stessa tecnica ha due usi: dal lato difensivo, eseguita con regolarità sulla propria rete, mostra quali servizi sono esposti e quali versioni vanno aggiornate; dal lato del monitoraggio, una scansione come questa lascia tracce riconoscibili nel traffico (molti SYN verso porte diverse in pochi secondi), utili da rilevare come primo segnale di ricognizione. Il passo successivo naturale è una scansione di vulnerabilità automatizzata, per verificare quali dei servizi individuati siano davvero sfruttabili.